Incident Response Plan

Northwind Cloud Ltd. - Internal - Version 3.2 - Effective 2026-07-01

1. Framework

The incident response process follows NIST SP 800-61 phases: Preparation; Detection and Analysis; Containment, Eradication and Recovery; and Post-Incident Activity.

2. Roles

Incident Commander (IC): owns decisions and coordination; does not perform hands-on fixes.
Communications Lead: internal and customer status updates every 30 minutes for SEV1, hourly for SEV2.
Scribe: maintains the incident timeline in the incident channel.
Subject Matter Experts: investigate and implement fixes at the IC's direction.
Security Lead: mandatory for any incident involving possible data exposure or credential compromise.

3. Detection and triage

Incidents are declared from monitoring alerts, SIEM detections, customer reports or engineer observation. The on-call engineer assigns an initial severity using the security policy section 7 and opens an incident channel named inc-<id>. When in doubt, declare a higher severity and downgrade later.

4. Containment

Prefer reversible containment: roll back the most recent deployment, disable the feature flag, isolate the host from the network, or revoke the credential. Preserve evidence before wiping: take disk snapshots and export relevant logs to the evidence bucket with object lock enabled.

5. Communication

SEV1 and SEV2 incidents require a status page update within 30 minutes of declaration. Confirmed personal-data breaches must be reported to the Data Protection Officer within 24 hours so that regulator notification can occur within 72 hours where required.

6. Post-incident review

A blameless postmortem is mandatory for SEV1 and SEV2 incidents and must be published within 5 business days. Each postmortem lists root cause, contributing factors, timeline, and action items with owners and due dates. Action items are tracked to closure in the engineering backlog.